

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
June 2025	Planning	Audit Program Risk Alignment	J. Daniels	Risk levels updated as part of annual revalidation
November 2024	Planning	Audit Program Risk Alignment	J. Daniels	Removed extra wording from Monitoring and Management Review defined risk area
September 2024	All	All	CA&AS	Created audit program

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Data Analysis.....	6
PLANNING: Reference Material	8
PLANNING: Fraud Template.....	10
CONTROL ASSESSMENT QUESTIONS	11
Key Control Question: 1. Regulatory Compliance / Mandatory Disclosures	11
Primary Test: Metric Calculation and Corroboration (MC001.P).....	12
Primary Test: Regulatory Requirements (RR001.P)	13
Key Control Question: 2. Data Security and Privacy	14
Primary Test: Data Protection (DP001.P).....	15
Primary Test: Separation of Duties (SD001.P).....	17
Key Control Question: 3. Voluntary Disclosures	18
Primary Test: Metric Calculation and Corroboration (MC001.P).....	19
Key Control Question: 4. Monitoring and Management Review (Substantiation and Validation)	20
Primary Test: Monitoring and Review (MM001.P)	21
Primary Test: Change Management (CM001.P).....	22
Key Control Question: 5. Materiality Assessment	23
Primary Test: Materiality Assessments (MA001.P).....	24

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

PROCESS AND OBJECTIVE

Environmental, social, and governance (ESG) information represents the sustainability factors that can affect corporate value and includes both quantitative and qualitative information. From a quantitative perspective, this can be financial or non-financial information, which includes all factual, statistical, and interpretive data, past, present, and projected related to ESG. Projected data includes ESG goals and targets. This may also be data specifically related to ESG initiatives or key performance metrics, such as greenhouse gas ("GHG") emissions, energy usage, packaging, waste and water consumption, ethics, human rights and human capital information and statistics, transparency, and governance. ESG quantitative data may also include financial information such as subsets of revenue or ratios using financial data. Examples of qualitative ESG information include a description of IBM's ESG strategy, views on public policies or IBM's positions, processes, and/or related governance information. ESG information may also include respective portions of related information from throughout our value chain, e.g., watershed impacts or GHG emissions in our supply chain and ESG information from wholly owned subsidiaries, joint ventures, or co-location data.

The release of ESG information required by laws and regulations is defined as mandatory reporting. For example, mandatory reporting includes statutory filings, including SEC filings, as well as government agency required statistics and country-specific disclosures.

The release of ESG information at IBM's discretion (i.e., not as required by law or regulation) is defined as voluntary reporting. For example, voluntary reporting includes the Impact Report and Addendum, the release of ESG information as part of a contract bidding process or as a result of a customer's or supplier's request or the broader release of information through avenues such as the CDP questionnaire, Global Reporting Initiative Index, Sustainability Accounting Standards Board Index, ESG ratings and rankings agencies, IBM's external webpages, among other forums.

The IBM Impact report is released annually to disclose progress across the three pillars of the IBM Impact framework: strengthening business ethics, fostering greater equity in communities, and protecting the environment. The report is further divided into the following subsections which comprise the ESG Reporting universe:

Governance - Ethical Impact	Social - Equitable Impact	Environment
Corporate Governance	Culture	Environmental Management System
Board of Directors	Supporting Our Employees	Energy & Climate
Business Ethics	Ethical Impact	Conservation & Biodiversity
Responsible Technology	Representation and Hiring Trends EEO-1	Pollution & Waste Management
	Diversity and Inclusion	Solutions for Sustainability
	Supply Chain Diversity	Supply Chain Environmental Responsibility
	Supply Chain Responsibility Supplier Audits Responsible Mineral Sourcing Supplier Diversity	
	Community Development Education & Skills Sustainability Accelerator Giving Volunteering	

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

PROCESS AND OBJECTIVE

(Continued)

This program is designed to provide a holistic view of the ESG process. ESG audits focus on specific ESG metrics and benchmarks that can be externally validated. A risk assessment should be performed to determine which of the sub-sections from the universe will be included in the scope of each audit in the ESG space.

Note: Detailed testing of many of the processes and transaction that comprise ESG reporting are covered by other audit programs (e.g. Procurement for Supply Chain and Corporate Social Responsibility for Contributions). For ESG reporting audits, testing should generally be limited to the unique risks as they relate to ESG Reporting rather than the underlying processes themselves. Careful consideration should be made when determining what (if any) testing is made and the depth of testing made where there is the potential to duplicate audit effort.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

PLANNING: Audit Program Risk Alignment

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Data Security and Privacy	High	Data Security and Privacy	DP001.P, SD001.P
Regulatory Compliance / Mandatory Disclosures	Medium	Regulatory Compliance / Mandatory Disclosures	MC001.P, RR001.P
Voluntary Disclosures	Medium	Voluntary Disclosures	MC001.P
Monitoring and Management Review	Medium	Monitoring and Management Review	MM001.P, CM001.P
Materiality Assessments	Medium	Materiality Assessments	MA001.P

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Internal Audit technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques:

Data to be Analyzed	Analysis to be Performed	Possible Concern
Impact Report Data Points	Review the listing of data points reported in the annual IBM Impact report and select a sample considering the following: - materiality of the data point or the aggregation of data points within a given scope area - the source of the data and methodology of the process used to gather and/or calculate the data - qualitative or quantitative claims that could be miscalculated and/or misleading or overstated to a reader	Reported metrics without complete and accurate supporting calculations and documentation could result in inaccurate reporting and damage to IBM image.
Data Reconciliations / Reporting Tie Out	Select a judgmental sample of reconciliations and/or data tie outs. Review for the following: Documented evidence of account reconciliation and review by management. Unreconciled variances were tracked, aged, and promptly resolved if necessary.	Reconciliations performed incorrectly or untimely could lead to a misstatement of IBM's position.
Regulatory Requirements	- Review a listing of regulatory requirements to determine whether any are applicable to the areas under audit. - If so, perform testing to ensure regulatory requirements were met and/or actions are being taken to comply. - Consider whether there will be future regulations that will impact the organization and ensure measures are being taken to enforce them.	Non-compliance and the release of unapproved disclosures could result in penalties/fines and/or reputational damage.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING AUDIT PROGRAM #51-00-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Possible Concern
Data Security & Privacy / Access Management	Obtain a listing of those with access to ESG Reporting metrics and supporting third-party data and review for the following: - Corporate instructions were enforced - Controls are in place for those with access to change reported metrics - Access to and use of third-party data is controlled	Failure to protect S/PI could enable fraudulent activity and misuse of data. Unauthorized access to third party information or to update externally reported information could result in dissatisfied third parties, damage to IBM's image, and expose IBM to risk of litigation.
Separation of Duties	- Evaluate the SOD analysis to determine if all tasks and roles were included in the analysis and that the assessment captured all conflicts. - Determine if the SOD analysis had been performed and approved in accordance with corporate instructions and all conflicts or potential conflicts had been mitigated or eliminated.	Lack of adequate processes for managing separation of duties (SOD) could allow individuals with excessive job responsibilities to edit data and conceal changes which could result in role conflicts and could lead to fraud.
Management Self Assessments	Review the basis for MSA ratings. - Review MSA reports and understand the justification for the rating - Identify instances where ratings have changed and assess whether information supports the changed rating.	Incorrect assessments may limit management's visibility of issues on a contract, portfolio, or business area. Information supporting MSA ratings may indicate process weaknesses requiring further review
Business Controls/Peer and Other reviews	Obtain reports by other Internal Audit teams, business controls, peer reviews, and reviews by the external organizations where relevant to aid in risk assessment and audit planning	Risks and issues may have been identified by other reviews and no action has been taken or management could have ignored the recommendations. If remediation actions are in progress, is it adequate to address risk? .
Applications and IT	Review the application listing to determine if there are any unique systems outside of BAU support systems (pricing, billing, revenue reporting etc.). Review should also include application access.	- Relevant systems may not have the required ASCA certifications - Continued Business Need check not performed, and employees may move to other roles leading to SOD conflicts Process or control weaknesses should be considered in the context of application controls, in particular reconciliations between systems
Risk Acceptances	Review the nature of any risk acceptances raised by the business during the audit period and/or any pending approval. Obtain action plans to address identified risks	- Risk acceptances may indicate process weaknesses, consideration should be given whether issues identified have been reviewed for other occurrences - Review the actions taken to meet deadlines, and reasons for committed deadlines to have been missed.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

PLANNING: Reference Material

US/CHQ

Corporate Organization Letters

- 110: Delegation of Authority – Contributions: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-110>
- 131: Delegation of Authority – Procurement: <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-131>

Corporate Instructions, Communications

- COM 115: Public release of Environmental, Social, and Governance Information: <https://w3.ibm.com/ibm/corporate-documents/mcc/com-115>

Corporate Instructions, Environmental Affairs and Product Safety

- IBM's corporate environmental policy was first issued in 1971 by IBM's Chief Executive Officer (CEO) Thomas J. Watson, Jr., and it has been updated several times since that initial release. The policy is periodically reviewed as a part of IBM's global environmental management system, and all updates are issued and approved by IBM's CEO: <https://w3.ibm.com/w3publisher/corporate-environmental-affairs/about/corporate-policy-and-instructions>

Corporate Instructions, Finance

- FIN 101: Control of Disbursements: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>
- FIN 154: Foreign Corrupt Practices Act - anti-bribery, record keeping, and internal control requirements: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-154>
- FIN 168: Business Amenities and Gifts: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-168-leg-168>
- FIN 182: Management Self Assessment of Control: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-182>

Data Protection Privacy

- Privacy and Security Terms (ibm.com): <https://w3.ibm.com/w3publisher/privacy-and-security-online-terms>
- IBM Privacy | IBM Trust Center | IBM: <https://www.ibm.com/support/pages/ibm-privacy>

European Commission

- Data Protection: http://ec.europa.eu/justice/data-protection/index_en.htm
- Data transfers out of Europe: https://ec.europa.eu/info/law/law-topic/data-protection/international-dimension-data-protection/rules-international-data-transfers_en
- Standard contractual clauses for data transfers: https://ec.europa.eu/info/law/law-topic/data-protection/international-dimension-data-protection/standard-contractual-clauses-scc_en

Information Commissioners Office

Guidance: <https://ico.org.uk/for-organisations/>

European Law resource

- Home: <http://eur-lex.europa.eu/homepage.html?locale=en>
- Example: <http://eur-lex.europa.eu/LexUriServ/LexUriServ.do?uri=OJ:L:2010:039:0005:0018:EN:PDF>

IBM Standards and Guidelines

- Home: <https://pages.github.ibm.com/ciso-psg/main/>

Privacy@IBM

- Home: <https://w3.ibm.com/ibm/privacy/knowledge-base/knowledge-base-a-z>
- GDPR: <https://w3.ibm.com/ibm/privacy/gdpr>

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

PLANNING: Reference Material
(Continued)

Compliance, Audit, Risk Mitigation & Management

- Audit A2.0@IBM - Risk Management: <https://w3.ibm.com/w3publisher/audit-a2-0-ibm/audit-a2-0/risk-management>

IBM Impact Report

- Reports and Policies: <https://www.ibm.com/impact/reports-and-policies>

Regulatory Requirements

- Securities and Exchange Commission (SEC) – United States – effective March 6, 2024
- Corporate Sustainability Reporting Directive (CSRD) – Europe – effective dates begin January 1, 2024 (filed in 2025)
- International Sustainability Standards Board (ISSB) – International – suggested effective date of fiscal year 2024
- A listing of applicable current and future regulations should be requested in the IDR.

Tools

- Workiva is the tool used to compile the IBM Impact Report
- Various tools are used to gather relevant data. Red Hat and/or other subsidiaries may use different tools to gather similar data for reporting. A listing of tools and spreadsheets should be requested in the IDR.
- An updated list of ASCA certified applications and spreadsheets should be obtained from the CAAS Global Application Risk Management (ARM) team.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Disclosing information without proper data validation and approval	Data validated prior to publishing with proper approvals; management monitoring and review	- Determine if data was supported by sufficient documentation and validated correctly prior to publishing - Determine if functional owner approved the data prior to being published.
Miscalculation of data points	Validation of data calculations	Determine if calculation was executed correctly
Application Access/Separation of Duties (SOD): The use of applications and databases, specifically those containing personal or sensitive data, as a result of unapproved or unnecessary system access, in order to access and/or use data for a reason other than its intended use and/or transfer to another party.	- Continued Business Need (CBN) reviews are performed for most applications. - System access levels associated to roles to maintain SOD.	- Review system access lists including the CBNs performed on the applications. Perform tests to validate some of the transactions performed. - Establish if accesses are in line with job roles, and that individuals do not have accesses to multiple ids to circumvent SOD controls.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Regulatory Compliance / Mandatory Disclosures

Objective:

To ensure externally reported data is compliant with regulatory/legal requirements, sufficiently supported by documented data and calculations, properly reviewed and approved by management, and aligned with IBM guidelines.

Risk/Exposure:

Non-compliance and the release of unapproved disclosures could result in penalties/fines and/or reputational damage. Errors in calculations that are manual and sometimes complex could result in external disclosure misstatement and/or hinder management's ability to make decisions.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Regulatory Compliance / Mandatory Disclosures

Primary Test: Metric Calculation and Corroboration (MC001.P)

Objective:

To validate whether externally disclosed metrics were supported by documented calculations and source documentation, authorized by management, and compliant with documented guidelines.

Approach:

Obtain a list of metrics from the most recent ESG external report. Understand which metrics are regulatory versus voluntary and whether subsidiary data is included or excluded.

Review with the ESG Controllershship to determine which data points are audit ready (processes and control points stable and documented). Select a sample of datapoints to test for the audit. For each sample, obtain the following:

1. The source data / inputs for the calculation
2. The source of the data (tool name, report name and parameters, 3rd party, emails, etc.)
3. The calculation for the metric, if quantitative
4. Dated approval of the calculation and any related review comments / email chains

Review the data for completeness and accuracy. Perform an independent recalculation of the metric based on the data provided. Inquire of any variances.

For regulatory compliance and mandatory disclosures, review the guidance to ensure the metric was calculated / reported as required. Understand whether any penalties or fines would be applicable (as outlined in RR001.P) and consider this higher risk when sampling.

For all disclosures, review the process flow and control documentation and corporate guidelines to ensure the metric was calculated as documented and that control points are documented.

Review the sources of the data against the listing of ASCA certifications completed, in progress, or planned (CAAS Global Application Risk Management (ARM) team). Review spreadsheets used to compile and/or calculate data. Validate whether ASCA criteria was met and/or the application/spreadsheet has been reported to the ARM team.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Regulatory Compliance / Mandatory Disclosures

Primary Test: Regulatory Requirements (RR001.P)

Objective:

To determine whether regulatory requirements were applicable and whether reporting was compliant with such requirements.

Approach:

Obtain a worldwide listing of current and future regulatory requirements (including rulings, directives, frameworks, standards, etc.) applicable to IBM.

Determine the country/countries and/or region(s) where the regulation is/will be applicable. Identify the consequences (e.g., fines/penalties) for non-compliance.

Review available guidance and inquire of the methodology used / to be used to comply with the regulation. Review any recent reviews performed internally or externally to identify any gaps between reporting and the requirements. Review any action plans to ensure gaps were remediated.

Recalculate any reported metrics, with extra consideration for complex calculations, as outlined in MC001. P.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Security and Privacy

Objective:

To ensure access to externally reported data is appropriately controlled, documented, and aligned with IBM guidelines and instructions. To ensure data shared by a third party is adequately protected and whether a valid data processing agreement existed between IBM and any Third Parties involved in the process when required.

Risk/Exposure:

Failure to protect PI and SPI could enable fraudulent activity, which could result in dissatisfied employees and misuse of data. Unauthorized access to third party information or to update externally reported information could result in dissatisfied third parties, damage to IBM's image, and expose IBM to risk of litigation.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Security and Privacy

Primary Test: Data Protection (DP001.P)

Objective:

Validate that adequate controls are in place to protect IBM employee and/or third-party PI and SPI.

Approach:

- Obtain a listing of data points that are comprised of information from 3rd parties. Inquire of the controls in place to ensure that data is secured and accessed only by those with a need to know.
- Identify what PI and SPI data is handled/processed by any third parties involved in the end-to-end process. Identify any regulations relating to data handling, including what types of data can be handled by third parties, or handled by anyone outside the country. Consider ways that PI and SPI could be compromised.
- Consider the following tests for any individuals involved in the end-to-end process that have access to PI or SPI. This includes IBM employees, contractor employees working for IBM departments, and vendor firms (their employees).
 - Access to data and applications (including granting, periodic revalidating, and revoking)
 - Separation of duties (including assessment of roles, tasks, and access to applications)
 - File transfers among IBM and vendors, including encryption and classification as IBM Confidential where required
 - Spreadsheet protection
 - Disaster recovery / business continuity planning. For example, if work is normally performed at IBM or vendor office facilities, but a disaster occurs and the plan calls for employees to work remotely, how secure are the means employees would have to perform their tasks at a remote location? Would unsecured telephone and internet access be used?
 - Data protection terms in contracts. Review contracts with vendors or contractor employees. How is data privacy assured? How does IBM monitor vendor protection of data? Are IBM's information technology standards in place, monitored, and enforced?

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Security and Privacy

Primary Test: Data Protection (DP001.P)

(Continued)

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets.

Complete the testing from the following link: <https://ibm.ent.box.com/file/1198251968388>

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities.

Complete the testing from the following link: <https://ibm.ent.box.com/file/1198263127550>

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Data Security and Privacy

Primary Test: Separation of Duties (SD001.P)

Objective:

To confirm that line organization duties were properly separated and that all transactions were appropriately approved.

Approach:

Review system access records for tools used in the ESG reporting process. This should include applications and tools used in gathering and retaining documentation and calculating and reporting the metrics. Review access capabilities of IBM personnel to determine that no conflicting system access capabilities exist within each system and between systems for each individual. Review the processes and related applications with management. Review the list of users of relevant systems along with what transactions they can execute. Verify that:

- Access is appropriately limited.
- Adequate separation of duties exists.
- Timely revalidation of access occurs.

Determine that the line organization has developed a separation of duties assessment, and that a management system exists to review and confirm that conflicts were identified and eliminated.

Determine that no individual has responsibility for more than one of the following related activities:

- Preparing and/or changing the data and/or calculation of the metric.
- Approving the metric and/or any changes for external reporting.
- Reconciling data.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Voluntary Disclosures

Objective:

To ensure externally reported data is sufficiently supported by documented data and calculations, properly reviewed and approved by management, and aligned with IBM guidelines.

Risk/Exposure:

The release of unapproved disclosures could result in misuse or wrong messages shared and could impact IBM's reputation in the marketplace. Errors in calculations that are manual and sometimes complex could result in external disclosure misstatement and/or hinder management's ability to make decisions. The release of unapproved disclosures could result in misuse or wrong messages shared and could impact IBM's reputation in the marketplace. Errors in calculations that are manual and sometimes complex could result in external disclosure misstatement and/or hinder management's ability to make decisions.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Voluntary Disclosures

Primary Test: Metric Calculation and Corroboration (MC001.P)

Objective:

To determine whether externally disclosed metrics were supported by documented calculations and source documentation, authorized by management, and compliant with regulatory and/or IBM guidelines.

Approach:

Obtain a list of metrics from the most recent ESG external report. Understand which metrics are regulatory versus voluntary and whether subsidiary data is included or excluded.

Review with the ESG Controllershship to determine which data points are audit ready (processes and control points stable and documented). Select a sample of datapoints to test for the audit. For each sample, obtain the following:

1. The source data / inputs for the calculation
2. The source of the data (tool name, report name and parameters, 3rd party, emails, etc.)
3. The calculation for the metric, if quantitative
4. Dated approval of the calculation and any related review comments / email chains

Review the data for completeness and accuracy. Perform an independent recalculation of the metric based on the data provided. Inquire of any variances.

For regulatory compliance and mandatory disclosures, review the guidance to ensure the metric was calculated / reported as required. Understand whether any penalties or fines would be applicable and consider this higher risk when sampling.

For all disclosures, review the process flow and control documentation and corporate guidelines to ensure the metric was calculated as documented.

Review the sources of the data against the listing of ASCA certifications completed, in progress, or planned (CAAS Global Application Risk Management (ARM) team). Review spreadsheets used to compile and/or calculate data. Validate whether ASCA criteria was met and/or the application/spreadsheet has been reported to the ARM team.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Monitoring and Management Review (Substantiation and Validation)

Objective:

To validate management monitoring, review, and change management processes and controls were documented and executed.

Risk/Exposure:

Lack of controls over the monitoring and management review of reporting could lead to inaccurate and/or unauthorized disclosures. Inconsistent/undocumented and/or unapproved methodology for changes could lead to inaccurate disclosures and reputational damage.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Monitoring and Management Review (Substantiation and Validation)

Primary Test: Monitoring and Review (MM001.P)

Objective:

To validate management monitoring and review processes and controls were documented and executed.

Approach:

Inquire to understand the management review process in place prior to finalizing reported data.

Validate that externally reported metrics were appropriately reviewed and approved.

Validate that the reported metrics agreed to the final support file.

Inquire of the strategy for goal attainment of metrics. Understand what steps are being taken to ensure we achieve the metric by the stated date and what is done when we know a metric is not on track.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Monitoring and Management Review (Substantiation and Validation)

Primary Test: Change Management (CM001.P)

Objective:

To validate change management processes and controls were documented and executed.

Approach:

Inquire of whether there were any changes to the metric or in the methodology of determining the metric since the prior report (or any planned for the future report). If so, obtain a listing of metrics that have changed since the prior external report or are planned to change prior to the next report. Inquire of the change management and validate the process was followed for a sample of metrics. If it is a change for the upcoming report, obtain available supporting documentation for the change and validate that the change management process will be executed.

Inquire of whether the prior year metrics were restated for consistency, and validate any documented changes were implemented.

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Materiality Assessment

Objective:

To validate that required materiality assessments were completed with documented support.

Risk/Exposure:

Inaccurate or incomplete assessments could hinder management's ability to make decisions. This could lead to sub optimal resource allocations, budget overages, or failure to detect inappropriate activities

ENVIRONMENTAL, SOCIAL, GOVERNANCE REPORTING

AUDIT PROGRAM #51-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Materiality Assessments

Primary Test: Materiality Assessments (MA001.P)

Objective:

To ensure that required materiality assessments were completed and retained with documented support.

Approach:

Obtain the most recent disclosed double materiality calculation and any other materiality calculations and supporting documentation.

Inquire of the methodology used and consider reperforming the calculation or parts of it to obtain reasonable assurance.

Validate that the calculation was sufficiently supported, reviewed, and approved.

Ensure sufficient support was retained to evidence the calculation and the review and approval process.